

Regulation induced Software Supply Chain Communication

Funding FOSS - Ignoring AI slop

05.08.2026 - Little Detritus - CCC AC

Cyber Resilience Act enters into force to make Europe's cyberspace safer and more secure

PRESS RELEASE

Publication 10 December 2024

Cyber Resilience Act enters into force to make EU How does the CRA address free and open-source software?

PRESS RELEASE
Publications

The CRA recognises that, to foster the development and deployment of free and open-source software, special attention should be paid to the nature of the different development models of software distributed and developed under free and open-source software licences.

This is why **only free and open-source software** that is made available on the market, and therefore supplied for distribution or use in the course of a commercial activity, falls in scope of the Cyber Resilience Act. Notably, the provision of products with digital elements qualifying as free and open-

Software Supply Chain Communication - for Compliance

Cyber Resilience Act enters into force to make EU How does the CRA address free and open- EXECUTIVE ORDER 14028, IMPROVING THE NATION'S CYBERSECURITY

PRI
Put

Software Supply Chain
Security Guidance

+

Cybersecurity Labeling
for Consumers

+

Workshops & Call for

**Improving the Nation's Cybersecurity: NIST's Responsibilities
Under the May 2021 Executive Order**

[Overview](#) | [Completed Assignments](#) | [Latest Updates](#)

supplied for distribution or use in the course of a commercial activity, falls in scope of the Cyber

Resilience Act. Notably, the provision of products with digital elements qualifying as free and open-

Software Supply Chain Communication - for Compliance

Cyber Resilience Act enters into force to make EU How does the CRA address free and open-

EXECUTIVE ORDER 14028, IMPROVING THE NATION'S CYBERSECURITY

Secure Software Development Framework SSDF

Softwa

Securi    

Cybers

for Cor **Overview**

Works

sup

Res

NIST has finalized SP 800-218A, [Secure Software Development Practices for Generative AI and Dual-Use Foundation Models: An SSDF Community Profile](#). This publication augments [SP 800-218](#) by adding practices,

nsibilities

open-

Software Supply Chain Communication - for Compliance

Cyber Resilience Act enters into force to make EU How does the CRA address free and open- EXECUTIVE ORDER 14028, IMPROVING THE NATION'S CYBERSECURITY

Secure Software Development Framework SSDF

U.S Security and Exchange Commission

Cybersecurity Risk Management, Strategy, Governance, and Incident Disclosure

nsibilities

open-

Software Supply Chain Communication - for Compliance

Cyber Resilience Act enters into force to make EU How does the CRA address free and open- EXECUTIVE ORDER 14028, IMPROVING THE NATION'S CYBERSECURITY

Secure Software Development Framework SSDF

U.S Security and Exchange Commission

Safeguarding artifact integrity across any software supply chain

Software Supply Chain Communication - for Compliance

Cyber Resilience Act enters into force to make EU How does the CRA address free and open- EXECUTIVE ORDER 14028, IMPROVING THE NATION'S CYBERSECURITY

Secure Software Development Framework SSDF

U.S Security and Exchange Comission

FINAL RULE

Softwa
Securi

Cybers
for Cor
Works

Chainguard

NIST

Foun

Google

citi

intel

CLOUD NATIVE
COMPUTING FOUNDATION

DATADOG

KUSARI

THE
LINUX
FOUNDATION

Software Supply Chain Communication - for Compliance

Cyber Resilience Act enters into force to make EU How does the CRA address free and open-

EXECUTIVE ORDER 14028, IMPROVING THE NATION'S CYBERSECURITY

Secure Software Development Framework SSDF

U.S Security and Exchange Comission



National Telecommunications and Information Administration
U.S. Department of Commerce

Section 515 Standards:

Guidelines for Ensuring and Maximizing the Quality, Objectivity, Utility, and Integrity of Information Disseminated
by the National Telecommunications and Information Administration

Software Supply Chain Communication - Why SCITT

1. publish supply chain data, decentralized, globally interoperable
2. Identify compliance critical communication (c3) within the ecosystem

Software Supply Chain Communication - The Ecosystem



Software Supply Chain Communication - The Ecosystem



Nationaal Cyber Security Centrum
Ministerie van Veiligheid en Justitie



Rijksinspectie Digitale Infrastructuur
Ministerie van Economische Zaken en Klimaat



Port of
Rotterdam

1. Market Surveillance Authority



Software Supply Chain Communication - The Ecosystem



Nationaal Cyber Security Centrum
Ministerie van Veiligheid en Justitie

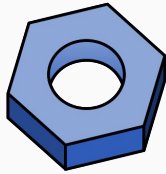


Rijksinspectie Digitale Infrastructuur
Ministerie van Economische Zaken en Klimaat



Port of
Rotterdam

1. Market Surveillance Authority



NixOS

2. FOSS - Up & Downstream

Software Supply Chain Communication - The Ecosystem



Nationaal Cyber Security Centrum
Ministerie van Veiligheid en Justitie

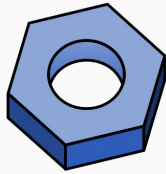


Rijksinspectie Digitale Infrastructuur
Ministerie van Economische Zaken en Klimaat



Port of
Rotterdam

1. Market Surveillance Authority



2. FOSS - Up & Downstream



NixOS



3. Dependents aka Manufacturers

Software Supply Chain Communication - The Ecosystem



1. Market Surveillance Authority



2. FOSS - Up & Downstream



3. Dependents aka Manufacturers



4. Your Forges

Software Supply Chain Communication - The Ecosystem



Nationaal Cyber Security Centrum
Ministerie van Veiligheid en Justitie

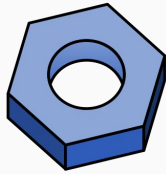


Rijksinspectie Digitale Infrastructuur
Ministerie van Economische Zaken en Klimaat



Port of
Rotterdam

1. Market Surveillance Authority



2. FOSS - Up & Downstream



NixOS



3. Dependents aka Manufacturers



4. Your Forges



5. White

AI

Blackhats

Software Supply Chain Communication - 4 ideas

1. publish supply chain data, decentralized, globally interoperable
2. Identify compliance critical communication (c3) within the ecosystem
 - a. by Market Surveillance Authorities (MSAs)
 - b. by FOSS Projects Up- and Downstream
 - c. by proprietary dependents

Software Supply Chain Communication - 1. idea

1. publish supply chain data, decentralized, globally interoperable



2. FOSS - Up & Downstream



3. Dependents aka Manufacturers



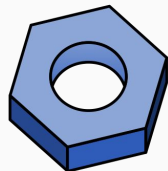
4. Your Forges

Software Supply Chain Communication - 1. idea

1. publish supply chain data, decentralized, globally interoperable

Standards Badges - SB

Allow FOSS projects to flag on their repositories which standards they implement



2. FOSS - Up & Downstream



NixOS



3. Dependents aka Manufacturers



4. Your Forges

Software Supply Chain Communication - The Ecosystem



Nationaal Cyber Security Centrum
Ministerie van Veiligheid en Justitie



Rijksinspectie Digitale Infrastructuur
Ministerie van Economische Zaken en Klimaat



Port of
Rotterdam

1. Market Surveillance Authority



2. Identify compliance critical communication (c3)
 - a. with Market Surveillance Authorities (MSAs)

Software Supply Chain Communication - The Ecosystem



Nationaal Cyber Security Centrum
Ministerie van Veiligheid en Justitie



Rijksinspectie Digitale Infrastructuur
Ministerie van Economische Zaken en Klimaat



**Port of
Rotterdam**

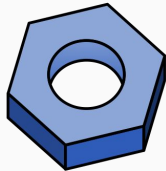
1. Market Surveillance Authority



2. Identify compliance critical communication (c3)
 - a. with Market Surveillance Authorities

MSAs should have a PKI

Software Supply Chain Communication - The Ecosystem



2. FOSS - Up & Downstream



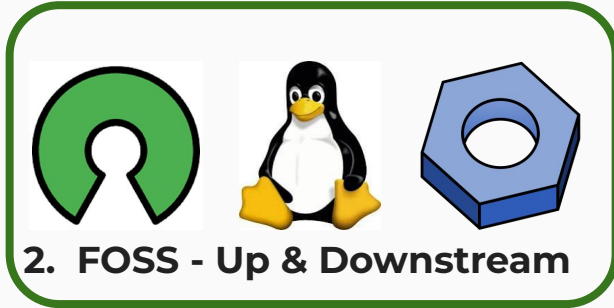
4. Your Forges

2. Identify compliance critical communication (c3)
 - b. by FOSS Projects Up- and Downstream

Software Supply Chain Communication - The Ecosystem

I) Write message

I)



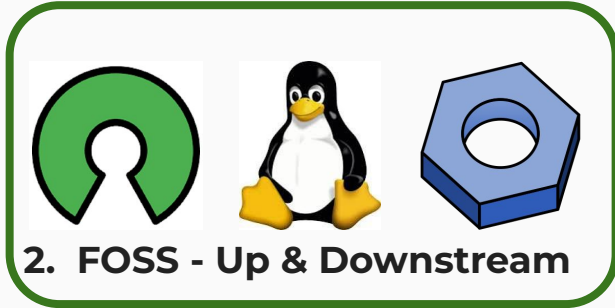
2. Identify compliance critical communication (c3)
 - b. by FOSS Projects Up- and Downstream



4. Your Forges

Software Supply Chain Communication - The Ecosystem

I) II)



4. Your Forges

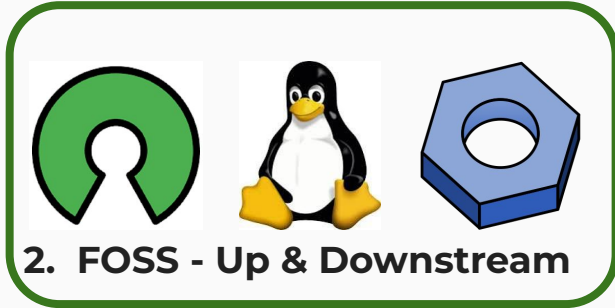
I) Write message
II) Publish hash of message
with forge account



2. Identify compliance critical communication (c3)
b. by FOSS Projects Up- and Downstream

Software Supply Chain Communication - The Ecosystem

I) II) III)



- I) Write message
- II) Publish hash of message with forge account
- III) Send mail to security@ with pointer to hash

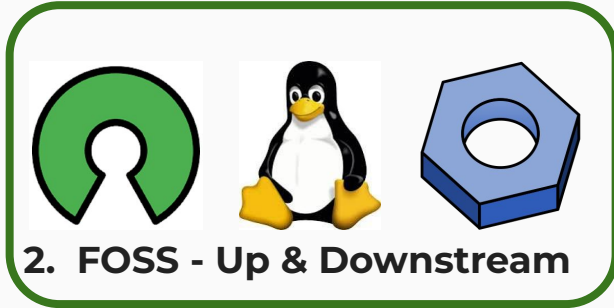


4. Your Forges

- 2. Identify compliance critical communication (c3)
 - b. by FOSS Projects Up- and Downstream

Software Supply Chain Communication - The Ecosystem

I) II) III)



IV)



- I) Write message
- II) Publish hash of message with forge account
- III) Send mail to security@ with pointer to hash
- IV) Run centrality measure on forge account of sender



4. Your Forges

- 2. Identify compliance critical communication (c3)
 - b. by FOSS Projects Up- and Downstream

Software Supply Chain Communication - The Ecosystem

I) Use Package



I)



3. Dependents aka Manufacturers

2. Identify compliance critical communication (c3)
c. by proprietary dependents



4. Your Forges

Software Supply Chain Communication - The Ecosystem

- I) Use Package
- II) get reset of properties of package (reset has UID)



I) II)



3. Dependents aka Manufacturers



4. Your Forges

- 2. Identify compliance critical communication (c3)
 - c. by proprietary dependents

Software Supply Chain Communication - The Ecosystem

- I) Use Package
- II) get reset of properties of package (reset has UID)
- III) send donation with UID



I) II) III)



3. Dependents aka Manufacturers



4. Your Forges

- 2. Identify compliance critical communication (c3)
 - c. by proprietary dependents

Software Supply Chain Communication - The Ecosystem

- I) Use Package
- II) get reset of properties of package (reset has UID)
- III) send donation with UID
- IV) send c3 with list of UIDs



I) II) III) IV)



3. Dependents aka Manufacturers



4. Your Forges

- 2. Identify compliance critical communication (c3)
 - c. by proprietary dependents

Software Supply Chain Communication - The Ecosystem

- I) Use Package
- II) get reset of properties of package (reset has UID)
- III) send donation with UID
- IV) send c3 with list of UIDs
- V) Asses validity by UIDs

V)



I) II) III) IV)



3. Dependents aka Manufacturers

- 2. Identify compliance critical communication (c3)
 - c. by proprietary dependents



4. Your Forges

Software Supply Chain Communication - The Ecosystem

- I) Use Package
- II) get reset of properties of package (reset has UID)
- III) send donation with UID
- IV) send c3 with list of UIDs
- V) Asses validity by UIDs

V)



I) II) III) IV)



3. Dependents aka Manufacturers



4. Your Forges

- 2. Identify compliance critical communication (c3)
 - c. by proprietary dependents

In scope - technical specs

1. Security and privacy guardrails for all stakeholders
2. Technical Soundness
3. Applicability

Out of scope - Interference with governance

1. Interference with the governance of FOSS Projects, thus:
 - a. Free choice of regulation to be adhered
 - b. Free choice of revealed information
 - c. Free choice of payment channels
 - d. Free choice of centrality measures
 - e. dataformats for payload content
 - f. etc. etc.
2. Create obstacles for
 - a. business innovation
 - b. market creation

Open Questions - Scope

1. Which Software supply chain regulation should be considered?
 - a. that is already out there?
 - b. that is in the making?
2. Are there best practices?
3. Which RFC are to be considered? (e.g. secure channels [RFC 9781](#))
4. Whom to talk to?
5. What did we miss?

Open Questions - Caveats

1. Trust is a social question, technology can help, not answer it.
2. Malicious fixes - downstream targets
3. Fraud
4. Impersonation and relay attacks
5. Open Source Software Stewards - a vehicle for money laundering?
6. What did we miss?

Open Questions - Caveats

1. Malicious fixes - downstream targets
2. Fraud
3. Impersonation and relay attacks
4. Open Source Software Stewards - a vehicle for money laundering?
5. What did we miss?

Asks

1. Are you familiar with:
 - a. EO 14028
 - b. SSDF
 - c. SEC Cyber Rule
 - d. SLSA
 - e. NTIA
 - f. other regulation ..
or compliance tooling?

Asks

1. Are you familiar with:
 - a. EO 14028
 - b. SSDF
 - c. SEC Cyber Rule
 - d. SLSA
 - e. NTIA
 - f. other regulation ..
or compliance tooling?
2. How to put badges on repositories?

Asks

1. Are you familiar with:
 - a. EO 14028
 - b. SSDF
 - c. SEC Cyber Rule
 - d. SLSA
 - e. NTIA
 - f. other regulation ..
or compliance tooling?
2. How to put badges on repositories?
3. Wanna come talk to ORCs - [Code and Compliance 27 Oct Brussels?](#)



Asks

1. Are you familiar with:
 - a. EO 14028
 - b. SSDF
 - c. SEC Cyber Rule
 - d. SLSA
 - e. NTIA
 - f. other regulation ..
or compliance tooling?
2. How to put badges on repositories?
3. Wanna come talk to ORCs [Code and Compliance 27 Oct Brussels?](#)
4. How to identify AI hats?

